October 20, 2026

Dear Prof. Lin,

We submit the manuscript "Formal Analysis and Fixing of Third-Party Online Payment Protocols" for consideration as a regular paper in IEEE Transactions on Dependable and Secure Computing.

The manuscript makes three main contributions:

1. **Formal analysis of deployed payment protocols.** Using TAMARIN, we analyze six third-party online payment protocols of the two dominant payment service providers in China under weakened channel assumptions. The analysis shows that the mainstream payment patterns do not bind the user's payment authorization to the intended order, which enables order tampering attacks.
2. **A practical attack variant and its prevalence.** We demonstrate a new variant of this attack on Android through implicit Intent hijacking and find that more than 25% of 461 tested versions of popular merchant applications are vulnerable.
3. **A formally verified countermeasure.** We propose Sealed Checkout Code (SCC), which protects every payment in a single protocol run without per-user keys, and verify with TAMARIN that it satisfies all security properties when both external channels are insecure. The formal models are publicly available at `https://doi.org/10.5281/zenodo.20303820`.

We believe the manuscript fits the scope of TDSC, which covers the formal verification and security of deployed systems. The work applies formal protocol analysis to payment infrastructure in daily use, confirms the findings on real merchant applications, and delivers a fix whose security is machine-checked rather than argued informally.

This manuscript extends our paper "When Authorization Loses Its Meaning: Breaking and Fixing Third-Party Online Payments," published in the Proceedings of the 35th USENIX Security Symposium (USENIX Security '26). The journal version replaces the conference countermeasure, which relied on trust on first use and left the first payment to each merchant unprotected, with SCC, and adds its design, security analysis, formal verification, and a comparison with transaction authentication mechanisms such as PSD2 dynamic linking. The conference paper and a previously published statement detailing the differences are uploaded with the submission.

At the request of the vendor, we refer to one of the two payment service providers as PSP-B in the manuscript. We reported the vulnerabilities to both providers, and both acknowledged them.

This manuscript has not been published elsewhere and is not under consideration by another journal or conference. All authors have approved the submission.

Thank you for your consideration.

Sincerely,

Jing Chen and Min Shi (corresponding authors), on behalf of all authors
School of Cyber Science and Engineering, Wuhan University, Wuhan 430072, China
E-mail: chenjing@whu.edu.cn, itachi@whu.edu.cn